

Role-Based Access Control Guide

A practical map of the defined roles, permissions, navigation rules, and proposed pharmacy-side experience.

SYSTEM PRINCIPLE	ONE SOURCE OF TRUTH
Permissions define what a role may do. Navigation defines what a role may discover. Backend rules must enforce both.	The canonical definitions live in <code>lib/rbac/permissions.dart</code> , <code>roles.dart</code> , and <code>role_config.dart</code> .

Prepared for the Duniya pharmacy platform

1. Executive Map

Duniya resolves a signed-in user into one canonical AppRole. The role receives a set of granular permissions and a separate set of visible navigation items. Pharmacy-side users are separated from Duniya network users using accountType and role resolution.

Resolution order

1. Read the current Firestore user document. 2. If accountType is Duniya, resolve to Duniya Admin or Duniya Staff. 3. Otherwise resolve the pharmacy role from the role field. 4. Missing or unknown values fall back to least privilege.

Portal naming rule

Pharmacy users see **Store Inventory**. Duniya users see **Product Catalogue**. These destinations are mutually exclusive in the sidebar and must remain separately enforced at route and backend levels.

Core roles

Role	Scope	Primary responsibility
Owner	Pharmacy	Full administration, finance, HR, inventory, operations
Outlet Manager	Pharmacy	Outlet operations, staff management, approvals
Pharmacist	Pharmacy	Clinical work, dispensing, POS, inventory
Pharmacy Technician	Pharmacy	Inventory, stock, receiving, expiry
Cashier	Pharmacy	POS transactions and basic sales
Sales Assistant	Pharmacy	POS, sales, and read-only inventory
Duniya Admin	Network	Network oversight and approvals
Duniya Staff	Network	Network operations and read access
Subscriber	Limited	Own billing, settings, notifications
Unknown	Limited	Safe fallback with minimal access

2. Pharmacy Navigation Matrix

This is the proposed pharmacy-side experience, organized around the work a person performs. It intentionally removes duplicate destinations and keeps read-only roles focused.

Area	Owner	Outlet Manager	Pharmacist	Technician	Cashier	Sales Assistant
Main	Home; My Pharmacies; HR; Finances; Pending Approvals	Home; HR; Finances	Home	Home	Home	Home
Inventory	Store Inventory	Store Inventory	Store Inventory	Store Inventory	Store Inventory	Store Inventory
Stock	Balances; Movements; Counts	Balances; Movements; Counts	Balances; Movements; Counts	Balances; Movements; Counts	Balances; Movements	Balances; Movements
Operations	Goods Received; Sales; POS	Goods Received; Sales; POS	Goods Received; Sales; POS	Goods Received	Sales; POS	Sales; POS
Monitoring	Batches; Low Stock; Replenishment; Cold Chain	All monitoring	Batches; Low Stock; Replenishment; Cold Chain	All inventory monitoring; Cold Chain	Batches; Low Stock	Batches; Low Stock
Clinical	Prescriptions; Insurance; Patients; Interactions	All clinical areas	All clinical areas	Patients read-only	Insurance verification; Interactions read-only	Insurance verification; Interactions read-only
Procurement	Purchase Orders	Purchase Orders	Purchase Orders	Purchase Orders	None	None
Tools	AI; BMI	AI; BMI	AI; BMI	BMI	BMI	BMI
Admin	Audit Logs; Settings	Audit Logs; Settings	Settings	Settings	Settings	Settings

Inventory naming invariant

Exactly one inventory destination is eligible at a time. Pharmacy: **Store Inventory**. Duniya: **Product Catalogue**. The parent row itself navigates to the active destination; it must not render a duplicate child row.

3. Action Rules by Pharmacy Role

The following summarizes the granular permissions currently defined in `role_config.dart`. View, create, edit, delete, approve, export, and manage are separate capabilities.

Domain	Owner	Outlet Manager	Pharmacist	Technician	Cashier	Sales Assistant
POS	Full	Full	Create/edit/discount	View	Create/edit	Create/edit
Inventory	Full + import/export	View/create/edit	View/create/edit	View/create/edit	View	View
Catalogue	Full	View/create/edit	View/create/edit	View/create/edit	View	View
Stock counts	Full + approve/delete	View/create/edit/approve	View/create/edit	View/create/edit	View	View
Goods received	Full	View/create/edit	View/create	View/create	None	View
Sales / dispensing	Full	View/create/edit	View/create/edit	View	View/create	View/create
HR	Full	View/create/edit	None	None	None	None
Finance	Full	View + reports	View	None	None	None
Purchase orders	Full	View/create/edit/approve	View/create	View/create	None	None
Prescriptions	Full	Full	Full	View	None	None
Insurance	Full	Full	View + verify	None	View + verify	View + verify
Cold chain	Full	View + alerts	View + alerts	View + alerts	None	None
Patient records	Full	Full	Full	View	View	View

Full means all permissions in that domain that are defined for the role. The exact enum names remain the source of truth.

4. Duniya Network Rules

Duniya Admin and Duniya Staff are not pharmacy-side roles. Their access is focused on the network layer and should not expose pharmacy operational navigation.

Role	Visible network areas	Action boundary
Duniya Admin	Home; Finances; Pending Approvals; Pharmacies; Network Stock; Onboarding; Network Analytics; Audit Logs; Settings	Full network administration, approval, finance, audit, and settings
Duniya Staff	Home; Finances; Pending Approvals; Pharmacies; Network Stock; Onboarding; Audit Logs; Settings	View-focused network operations; no approval or analytics management
Subscriber	Home; Finances; Settings	Own billing and settings only
Unknown	Home; Settings	Minimal safe fallback

5. Implementation Guardrails

Guardrail	Rule
Route guard	Every route must verify the relevant Permission before rendering protected data or actions.
Backend enforcement	Firestore rules and server-side functions must enforce ownership, outlet scope, and action permissions. Sidebar visibility is not security.
Owner scope	Owners use their own user reference; staff resolve through ownerRef using <code>AccessControl.parentRef()</code> .
Least privilege	Missing <code>accountType</code> , missing role, or unknown values must resolve to a restricted role and must never grant Duniya Admin access.
No duplicate inventory	The pharmacy portal exposes Store Inventory only. The Duniya portal exposes Product Catalogue only. Never render both in one context.
Real data only	Empty states are valid. Do not add local mock records, seeded dashboards, demo claims, or fabricated inventory to make a page look populated.

Known alignment checks

The navigation matrix still contains both inventory enum values for several roles, but the sidebar applies the portal-specific filter. Pharmacists and technicians have `pharmaciesView` permission while their proposed navigation does not show My Pharmacies. Outlet Manager has broad clinical permissions that should be reviewed against operational policy.